

UAC Bypass in Windows Privilege Escalation

User Account Control (UAC) is a security feature in Windows that helps prevent unauthorized changes to the operating system. While UAC is a valuable tool for limiting the damage from malicious software, it can be bypassed in certain scenarios, particularly when an attacker is trying to escalate privileges. This can happen if the attacker already has a user-level shell but needs to elevate to an administrator level.

Bypassing UAC is often a necessary step for privilege escalation attacks, especially when the "Medium Mandatory Level" is set for a user account, which prompts for confirmation via a UAC dialog box. Without graphical access or the ability to interact with the UAC prompt, attackers need to use various techniques to bypass this protection.

1. Enumeration to Check UAC Status

The first step in a UAC bypass is determining whether UAC is enabled or disabled. If UAC is enabled, a user must confirm actions that require administrative privileges, leading to a UAC prompt. If UAC is disabled, the system will not prompt the user for consent.

STEPS TO ENUMERATE UAC SETTINGS:

Action	Command
Check the current user's group and privileges	whoami /groups
Look for the "Medium Mandatory Level" (indicating a UAC prompt will appear)	

Action	Command
Check if UAC is enabled or disabled	REG QUERY HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\ / v EnableLUA

→If UAC is enabled: The EnableLUA registry key will show a value of 0x1.

→If UAC is disabled: The EnableLUA registry key will show a value of 0x0.

Explanation:

If UAC is enabled, a standard user account will trigger a UAC dialog when attempting to run administrative tasks. If UAC is disabled, it's easier to escalate privileges without needing to interact with a prompt.

2. Common UAC Bypass Techniques

There are multiple methods to bypass UAC, some of which work by exploiting flaws in UAC's configuration or the way Windows handles certain executables. Below are a couple of well-known UAC bypass methods:

UAC BYPASS USING CMSTPLUA

The **CMSTPLUA** bypass is a known method for circumventing UAC on Windows systems. This method utilizes a Windows executable (UACBypassCMSTPLUA.x86.exe) that bypasses the UAC prompt, allowing execution of elevated commands.

Steps to exploit:

Action	Command
Download the CMSTPLUA UAC bypass executable	https://github.com/tijme/cmstplua-uac-bypass/blob/master/UACBypassCMSTPLUA.x86.exe

Action	Command
Run the UAC bypass and execute a command (e.g., whoami)	UACBypassCMSTPLUA.x86.exe cmd /k whoami

Explanation:

The CMSTPLUA method exploits a vulnerability in the UAC mechanism and bypasses the prompt by running a custom executable that circumvents the confirmation process. This allows the attacker to gain administrative privileges without interacting with the UAC prompt.

3. Manual UAC Bypass

Manual UAC bypass can be done through registry editing and exploiting Windows behavior with certain executables. This bypass works by manipulating the system registry settings or using specific executable files that can elevate privileges without triggering a UAC prompt.

Steps to perform a manual UAC bypass:

Action	Command
Check if the user has "Medium Mandatory Level" and can trigger UAC	whoami /groups
Check UAC settings to confirm its status	REG QUERY HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\ /v EnableLUA
Disable UAC (if needed)	REG ADD HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System /v EnableLUA /t REG_DWORD /d 0 /f

Action	Command
Set UAC to a less restrictive level (to bypass UAC prompt)	REG ADD HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System /v ConsentPromptBehaviorAdmin /t REG_DWORD /d 0 /f
Restart the system (if required)	

Explanation:

This technique manually disables UAC by modifying the registry. Changing the EnableLUA setting to 0 disables the UAC prompt, allowing an attacker to execute elevated commands without needing to confirm the action.

4. UAC Bypass with Tools like UACME

The **UACME** tool is a repository of methods and scripts that help exploit various UAC bypass techniques. By using UACME, an attacker can automate the process of bypassing UAC and escalating privileges in a Windows environment.

Steps to use UACME:

Action	Command
Download UACME from GitHub	https://github.com/hfiref0x/UACME
Use the tool to trigger a UAC bypass	UACME.exe -e cmd.exe

Explanation:

The UACME tool provides a variety of pre-configured UAC bypass methods, allowing an attacker to quickly find and exploit a bypass mechanism suited for the current system configuration. Using this tool helps automate the process of UAC bypass, saving time during an attack.

5. Additional UAC Bypass Techniques and Resources

- Default UAC settings:** If the system has been configured with default UAC settings, attackers can exploit vulnerable executables that are allowed to bypass UAC without the user's consent. For example, certain Microsoft applications or trusted executables (like `cmstplua.exe`) can be used to trigger elevation without a prompt.
- Exploiting Trust Levels:** Certain system files or trusted applications can be exploited to bypass UAC if an attacker can convince the system to run a payload with higher privileges.

ADDITIONAL RESOURCES:

- [TryHackMe UAC Bypass Room](#)
- [UACME GitHub Repository](#)
- [Manual UAC Bypass Guide](#)

Conclusion

Bypassing UAC is an essential technique for privilege escalation in Windows environments, especially when the attacker is operating from a limited user account. Understanding how to enumerate the UAC status, and using tools and manual techniques to bypass UAC, is crucial for exploiting this vulnerability. By using methods like CMSTPLUA or tools such as UACME, attackers can escalate privileges to gain administrative or SYSTEM access, making it an important skill in a penetration tester's toolkit.